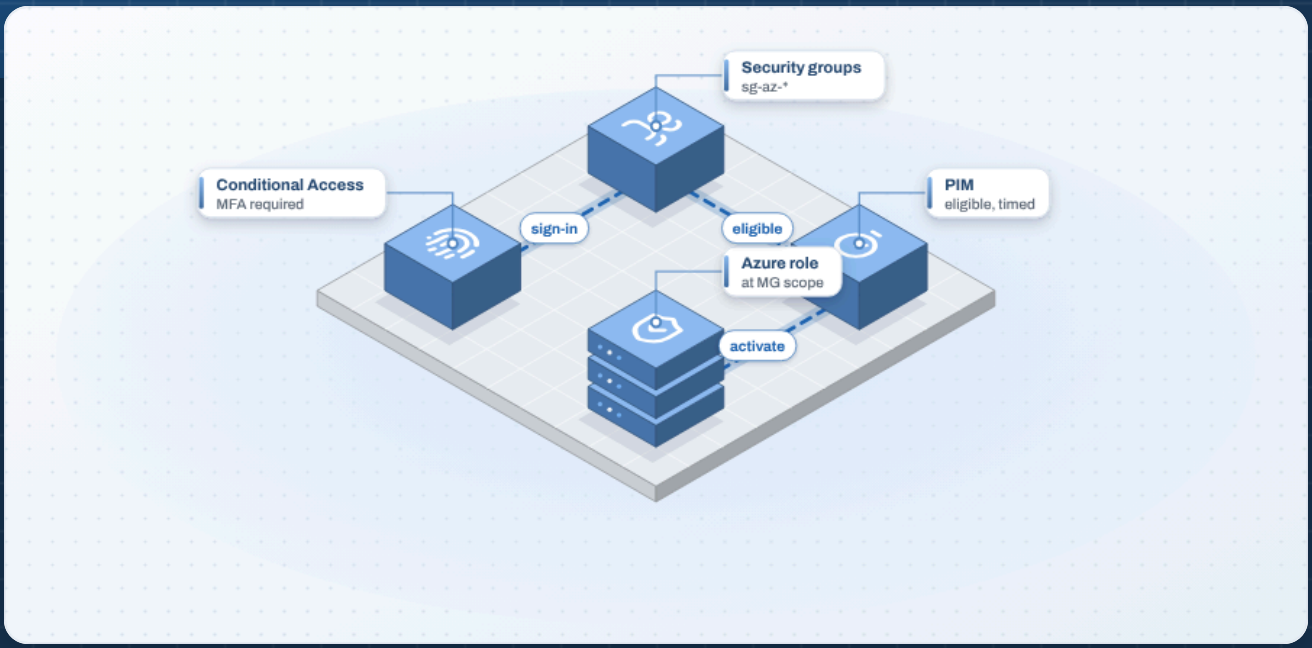
STANDARD OPERATING PROCEDURE · FIELD GUIDE SERIES

SOP-AZ-104

Hardening Identity and Access in Azure

Entra ID security groups, Azure roles at management group scope, Privileged Identity Management, Conditional Access and a role-to-permission matrix tested with real accounts.

Identity & Access | Entra ID | PIM



DOCUMENT ID	SOP-AZ-104
VERSION	1.1
EFFECTIVE	October 2026
AUDIENCE	Identity administrators, platform engineers, reviewers
AUTHOR	Richmond Dieujuste, Principal Consultant

Rich Dieu IT Solutions LLC · richdieu.com

Sanitized reference edition · client identifiers removed

Contents

1. Concepts You Need First 2

1.1 The five groups 2

2. Access, Prerequisites and Planning 4

2.1 Prerequisites checklist 4

3. Procedure in the Azure Portal 5

4. Template · Identity Review 8

5. Verification and Troubleshooting 9

5.1 Verify 9

5.2 Troubleshooting 9

6. Summary, Glossary and Review 10

6.1 Chapter summary 10

6.2 Glossary 10

6.3 Framework references 10

LEARNING OBJECTIVES

After working through this procedure you will be able to:

- Explain why people join groups and groups hold roles, and where PIM fits.
- Configure group-based roles, PIM eligibility and an MFA Conditional Access policy.
- Test the role matrix with one account per role and record allowed and denied results.

CHAPTER 1

Concepts You Need First

Most cloud breaches start with an identity, not a network. If every person holds roles directly, removing access means finding every assignment; if roles are held by groups, removing a person from one group removes everything. Privileged roles should exist only when someone is using them.

KEY CONCEPT · A BADGE, A DOOR LIST AND A VISITOR PASS

A person has a badge (their account), the door list names teams not people (groups hold roles), and anyone who needs the server room asks for a visitor pass that expires at the end of the day (PIM activation).

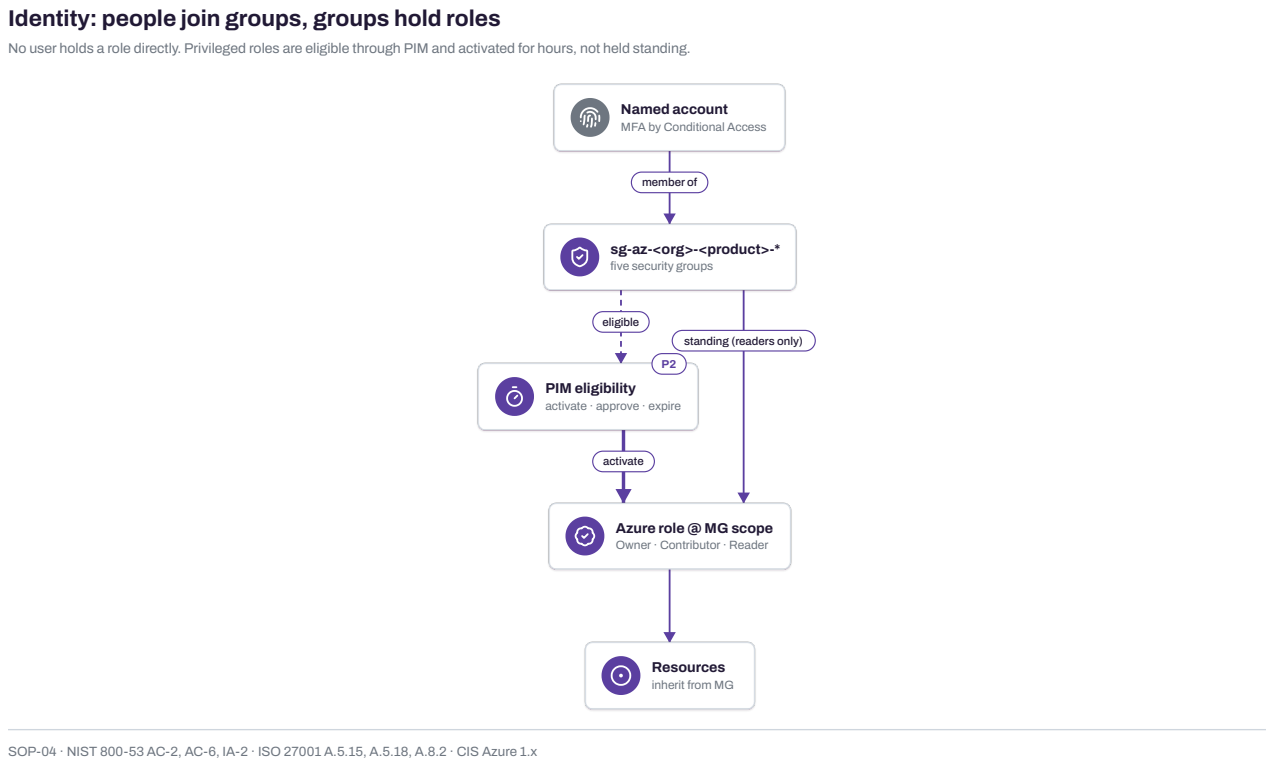


Figure 1. People join groups; groups hold roles at management group scope; privileged roles are eligible and activated for hours.

1.1 The five groups

Group	Role and scope	Standing or eligible
`-owners`	Owner at the product root	Eligible (PIM), 4 hours

Group	Role and scope	Standing or eligible
`-platform-ops`	Contributor on Platform; Resource Policy Contributor at the root if the client asks in writing	Standing
`-customer-ops`	Contributor on Customers	Eligible (PIM), 8 hours
`-security`	Security Reader and Reader at the root	Standing
`-auditors`	Reader at the root	Standing

CAUTION · PIM NEEDS ENTRA ID P2

Without P2, eligible assignments fail. Record the missing licence as a finding and do not quietly fall back to standing Owner.

CHAPTER 2

Access, Prerequisites and Planning

Task	Role	Notes
Create groups	Groups Administrator	Membership is the client's decision
Assign Azure roles	User Access Administrator or Owner at the scope	Assign to groups only
PIM role settings	Privileged Role Administrator	P2 licence
Conditional Access	Conditional Access Administrator	P1 licence
Read for review	Reader plus Security Reader and Directory Readers	No write needed

2.1 Prerequisites checklist

- ☐ Entra ID P1 (Conditional Access) and P2 (PIM) licences confirmed or recorded as findings.
- ☐ Two break-glass accounts exist, excluded from Conditional Access and monitored.
- ☐ Client approves group membership in writing.
- ☐ Test accounts approved for the matrix test.

CHAPTER 3

Procedure in the Azure Portal

NOTE · HOW THESE SCREENS WERE CAPTURED

Screens in this chapter were captured read-only from a live engagement tenant. Client, product and people names, tenant, subscription and object IDs, email addresses and public IPs are replaced (`org`, `app`, `Contoso`, `00000000-…`, `203.0.113.10`). Compliance figures and unrelated rows are blurred. Portal labels move over time; the setting names are what matter.

STEP 1 Check the groups exist and are owned

1. Go to **Microsoft Entra ID › Groups › All groups** and search `sg-az-`.
2. Each group should have an owner and only the members the client approved.

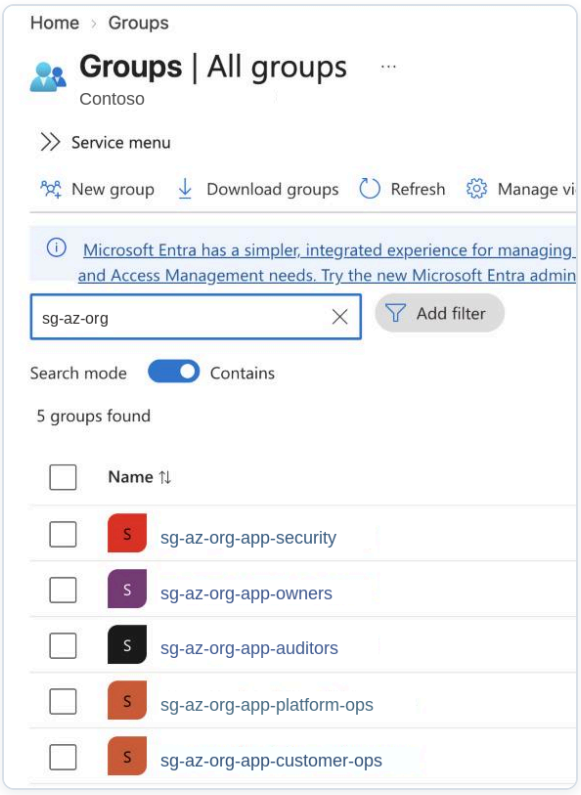


Figure 2. The five engagement security groups, filtered by prefix. Object IDs cropped.

STEP 2 Assign Azure roles to groups only

1. Open the product root management group › **Access control (IAM) › Add › Add role assignment.**

2. Pick the role, then **Members › Assign access to: User, group, or service principal** and select the group.
3. Readers and auditors get standing Reader; platform operators get Resource Policy Contributor only on the client's written request.

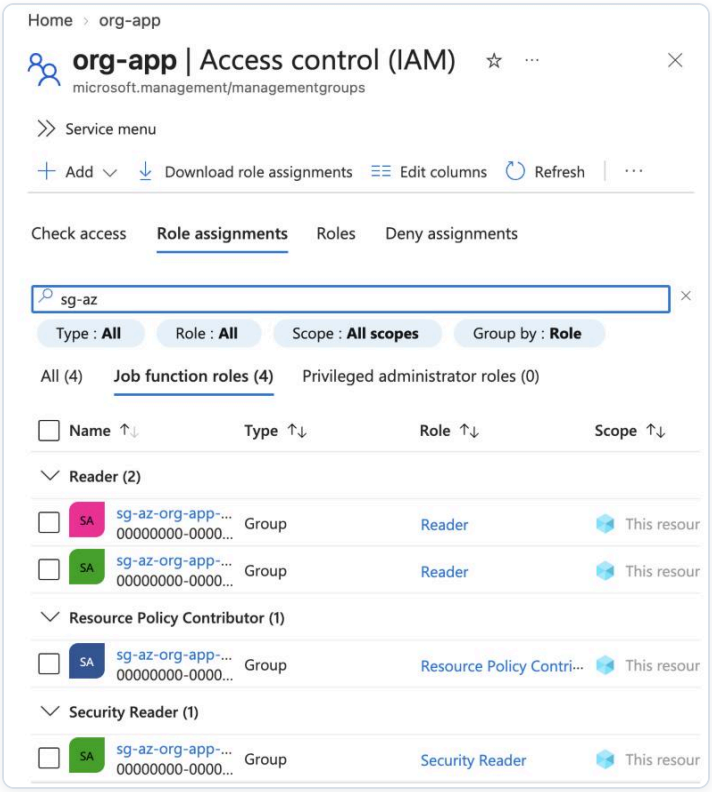


Figure 3. Job-function roles at the product root, filtered to the security groups: all held by groups.

STEP 3 Make privileged roles eligible

1. **Privileged Identity Management › Azure resources:** select the management group, then **Roles › Add assignments.**
2. Role Owner (or Contributor), member the owners group, **Assignment type: Eligible**.
3. In **Settings** for the role: maximum activation 4 to 8 hours, require MFA and justification, require approval for Owner.

STEP 4 Enforce MFA with Conditional Access

1. **Entra ID › Protection › Conditional Access › Create new policy.**

2. Users: all users, excluding the two break-glass accounts. Target resources: all cloud apps. Grant: **Require multifactor authentication**.
3. Start in **Report-only**, review sign-in logs for a week, then switch to **On**. Add a second policy that blocks legacy authentication.

> **GOOD PRACTICE · REPORT-ONLY FIRST**
> Report-only shows who would have been blocked without blocking anyone. A week of sign-in logs catches service accounts and old clients before they break.

STEP 5 Review standing privilege and test the matrix

1. Run `SOP-04-identity-review.ps1`. It warns on any user holding Owner or User Access Administrator directly.
2. Each warning is a finding unless it is a documented, time-limited exception (for example the engineer's access during the build, removed at hand-over).
3. Sign in as one test account per group; try one action the role allows and one it does not; record expected, actual, UTC time and the activity log correlation ID.

CHAPTER 4

Template · Identity Review

SOP-04-IDENTITY-REVIEW.PS1 · IDENTITY REVIEW · READ ONLY POWERSHELL

```powershell
<#  SOP-04 template: identity and access review (read-only). Exports the role-to-permission matrix inputs.
    Needs Reader at the product root plus Directory Readers (Entra). PIM data needs Entra ID P2.     #>
param([string]$RootMg = '<org>-<product>', [string]$Out = './identity-review')
New-Item -ItemType Directory -Force $Out | Out-Null
$root = "/providers/Microsoft.Management/managementGroups/$RootMg"

# 1. Who holds what, where (standing assignments). Flag users holding Owner / UAA directly.
$ra = Get-AzRoleAssignment -Scope $root | Select-Object DisplayName, SignInName, ObjectType, RoleDefinitionName,
Scope
$ra | Export-Csv "$Out/01-role-assignments-root.csv" -NoTypeInformation
$ra | Where-Object { $_.ObjectType -eq 'User' -and $_.RoleDefinitionName -in 'Owner','User Access Administrator'
} |
      ForEach-Object { Write-Warning "Standing privileged user: $($_.SignInName) holds $($_.RoleDefinitionName)"
}

# 2. Group membership (the RBAC model is groups, never users)
Get-AzADGroup -DisplayNameStartsWith "sg-az-$RootMg" | ForEach-Object {
  $g = $_; Get-AzADGroupMember -GroupObjectId $g.Id | Select-Object @{n='Group';e={$g.DisplayName}}, DisplayName,
UserPrincipalName
} | Export-Csv "$Out/02-group-members.csv" -NoTypeInformation

# 3. PIM eligible assignments (P2)
$r = Invoke-AzRestMethod -Method GET -Path
"$root/providers/Microsoft.Authorization/roleEligibilityScheduleInstances?api-version=2020-10-01"
if ($r.StatusCode -eq 200) { ($r.Content | ConvertFrom-Json).value.properties | Select-Object principalId,
roleDefinitionId, memberType |
                           Export-Csv "$Out/03-pim-eligible.csv" -NoTypeInformation }
else { Write-Warning "PIM not readable (no P2 licence?) - record as a finding, not a pass." }

# 4. Conditional Access and MFA (Microsoft Graph; Policy.Read.All)
Connect-MgGraph -Scopes 'Policy.Read.All','Directory.Read.All' -NoWelcome
Get-MgIdentityConditionalAccessPolicy | Select-Object DisplayName, State,
  @{n='Users';e={$_.Conditions.Users.IncludeUsers -join ','}}, @{n='Grant';e={$_.GrantControls.BuiltInControls -
join ','}} |
  Export-Csv "$Out/04-conditional-access.csv" -NoTypeInformation
(Get-MgPolicyIdentitySecurityDefaultEnforcementPolicy).IsEnabled | Set-Content "$Out/05-security-defaults.txt"

# 5. Matrix test: sign in as a test account from each group and try one allowed and one denied action.
#    Record: account (role placeholder), action, expected, actual, timestamp, evidence (screenshot/activity log
ID).
```

EXAMPLE · MATRIX TEST LOG CSV

```csv
Role,Account,Action,Expected,Actual,UtcTime,CorrelationId
auditors,test-auditor,Read policy compliance,Allow,Allow,2026-10-15T14:02:11Z,<id>
auditors,test-auditor,Delete a lock,Deny,Deny (AuthorizationFailed),2026-10-15T14:03:40Z,<id>
```

CHAPTER 5

Verification and Troubleshooting

5.1 Verify

- [ ] Role assignment export shows groups only, or documented exceptions.
- [ ] PIM export lists Owner and Contributor as eligible, not active.
- [ ] Conditional Access export shows the MFA policy On and legacy authentication blocked.
- [ ] Matrix log has one allowed and one denied result per role.

5.2 Troubleshooting

Symptom	Likely cause and fix
PIM assignment fails with AadPremiumLicenseRequired	No P2 licence. Record a finding; do not substitute standing Owner.
Conditional Access blade says you do not have access	Reader is not enough. Ask for Security Reader or Conditional Access Administrator.
Group change does not take effect	Tokens are cached; sign out and in again, or wait for the token lifetime.

CHAPTER 6

Summary, Glossary and Review

6.1 Chapter summary

- People join groups; groups hold roles; nothing is assigned to a person directly.
- Owner and Contributor are eligible through PIM with MFA and expiry.
- Conditional Access enforces MFA, rolled out from report-only.
- The matrix is proven with real sign-ins, not by reading settings.

Check your understanding

1. Why assign roles to groups rather than users?
2. What does PIM add over a standing assignment?
3. Why keep two break-glass accounts out of Conditional Access?
4. What two results does the matrix test record per role?

6.2 Glossary

PIM	Privileged Identity Management; time-bound, approved activation of roles.
Conditional Access	Entra ID policies that set conditions, such as MFA, on sign-in.
Break-glass account	Emergency account excluded from normal controls and closely monitored.

6.3 Framework references

Framework	Controls
CIS Azure Foundations	1.x
NIST SP 800-53 R5	AC-2, AC-5, AC-6, IA-2, IA-5
ISO/IEC 27001:2022	A.5.15, A.5.18, A.8.2, A.8.5
HIPAA Security Rule	164.312(a)(1), 164.312(d)